

ADAPT: Adaptive Camouflage-based Deception Orchestration For Trapping APT

Technologies Used

The researchers used a combination of hardware, virtualization software, networking tools, and custom applications to build their honeypot environment.

- **Hardware and Virtualization:**
 - **Host Machines:** Three Intel Core i7 desktop processors with 32 GB RAM and 500 GB SSDs served as the foundation.
 - **Virtual Machines (VMs):** Six VMs were created to simulate the organization's network, running on the host machines.
 - **Operating Systems:** The VMs used both Ubuntu 20.04 LTS (for researcher and server machines) and Windows 10 (for professor machines) to create a diverse environment.
- **Networking and Services:**
 - **Cloud Infrastructure:** Two cloud servers (DigitalOcean droplets) were used: one as a redirection engine and another to host the VPN server.
 - **VPN:** OpenVPN was used to create a secure, unified network connecting all the VMs, mimicking a real corporate network.
 - **Web Server:** A vulnerable version of Apache 2.4.49 was intentionally used to serve as an entry point for attackers.
 - **Development Stacks:** The LAMP (Linux, Apache, MySQL, PHP) and MERN (MongoDB, Express.js, React, Node.js) stacks were installed on developer machines to add realism.
 - **Log Management:** Apache Kafka was used as a distributed messaging system to centrally collect logs from the "Chatterbox" application.
- **Custom Software:**
 - **Chatterbox Application:** A custom-built application that functioned as a chat interface but secretly collected and transmitted system logs for monitoring attacker activity. It was developed for both Linux and Windows environments.

How They Captured the APTs

The capture process was not passive; it was an active strategy designed to lure and engage APTs in a believable, multi-stage environment.

1. **Creating an Attractive Target:** They designed a fictitious research organization, the "Pandemic Studies & Risk Surveillance Center (PSRSC)," which appeared to handle sensitive data of national importance to India. This context was specifically chosen to attract the interest of nation-state APT groups.
2. **Orchestrating Attack Paths:** They intentionally placed vulnerabilities and clues within the network that mirrored the known Tactics, Techniques, and Procedures (TTPs) of specific APT groups. An attacker compromising the public-facing vulnerable web server would find credentials leading them deeper into the network, encouraging further engagement.
3. **Providing a Full Lifecycle Environment:** Unlike simple honeypots, the ADAPT network allowed attackers to perform actions across the entire cyber kill chain. They could move laterally from low-privilege to high-privilege machines, conduct reconnaissance, and ultimately exfiltrate fake sensitive data from an FTP server. This prolonged engagement was crucial for capturing detailed behavioral data.

How They Identified an Attacker as an APT

The researchers differentiated between automated bots, amateur attackers, and sophisticated APTs by analyzing the depth and nature of the interactions. An attacker was identified as an APT based on the following characteristics:

- **Goal-Oriented, Multi-Stage Attacks:** While bots performed simple scans and amateurs attempted basic defacements, APTs exhibited prolonged and systematic behavior. They didn't stop after the initial compromise; they navigated the network with clear objectives, such as finding and exfiltrating valuable data.
- **Knowledge of Specific Vulnerabilities:** Sophisticated actors used definitive payloads to exploit specific, known vulnerabilities, rather than just trying random exploits.
- **Stealth and Persistence:** The 22-day campaign observed from Hong Kong was a clear indicator of an APT. This group moved carefully, escalated privileges, deployed backdoors to maintain persistence, and used advanced tools, which is characteristic of APT operations, not automated attacks.

How They Classified the APT (Attribution to a Specific Group)

Once an attacker was identified as an APT, they were classified or associated with a specific group through a careful correlation of multiple evidence points.

1. **Mapping Observed Behavior to MITRE TTPs:** The primary method was to systematically map the attacker's actions to the MITRE ATT&CK framework. The researchers would identify the exact techniques used, such as "T1190: Exploit Public-Facing Application" or "T1486: Data Encrypted for Impact".
2. **Analyzing Tools and Malware:** The specific software deployed by the attackers was a critical clue. In the 22-day campaign, the researchers identified well-known tools like EarthLucas RAT, Winnti backdoor, Cobalt Strike, and Pandora ransomware.

3. **Correlating with Threat Intelligence:** They compared the collected evidence—the TTPs, the malware/tools used, and the source IP addresses—with existing public threat intelligence reports on known APT groups. The classification was made when there was a strong alignment. For example, the use of EarthLucas RAT and the Winnti backdoor, coupled with the observed TTPs, directly corresponds to the known tactics of the Chinese state-sponsored group "Earth Lucas," allowing the researchers to attribute the attack to them